



**AI CODE
SUMMIT**

by **SIMPLY**

HOW TO HANDLE AN ENDLESS STREAM OF VULNS

Building a pipeline for autonomous work



**AI CODE
SUMMIT**

by **SIMPLY**

SPEAKER

Pavel Vostrikov

- 15 years in web development
- Architect and hands-on engineering manager for a web platform at **Kaspersky**
- Since 2025, I work only with **spec-driven** development



THE TALK IN ONE SLIDE

1. Vulnerability process: HLA, threat model, and third-party code scanning
2. Vulnerability scoring and auto-fix for mature companies
3. Security Champion — fast and low-cost start



AI CODE
SUMMIT

by SIMPLY

PROBLEM #1

OLD UNKNOWN VULNERABILITIES

Automated research and public CVEs **expose long-lived** issues.



**AI CODE
SUMMIT**

by **SIMPLY**

PROBLEM #1

OLD UNKNOWN VULNERABILITIES

Example #1: Copy Fail (CVE-2026-31431) — Linux kernel bug since **2017**

- First reaction (April): container environments are "not affected", only Linux hosts are vulnerable
- Update (May 1): via **shared image cache** you can escalate privileges in a k8s cluster



**AI CODE
SUMMIT**

by **SIMPLY**

PROBLEM #1

OLD UNKNOWN VULNERABILITIES

Example #2: CVE-2026-21536 — critical RCE (CVSS 9.8) in Microsoft cloud component **Devices Pricing Program**.

The finding is linked to the **XBOW** platform.

- **Attacker actions:** run code remotely in the service context.
- **Attack result:** full compromise of processed data and related infrastructure without local access to the victim machine.



**AI CODE
SUMMIT**

by **SIMPLY**

PROBLEM #1

OLD UNKNOWN VULNERABILITIES

Example #3: heap overflow in **NFSv4** replay cache

- The issue exists since **~2003**
- Found with **Claude Code**
- Two coordinated clients to **nfsd** write outside the buffer
- For an attacker this is a path to **kernel panic** and **possible code execution on the server** with kernel privileges



AI CODE
SUMMIT

by SIMPLY

PROBLEM #2

CVE SPAM AND AI SLOP

- Sharp growth: >50k CVEs in 2026 ([FIRST forecast](#)) vs ~25k in 2023
- Public repos and bounty programs are overloaded with noise
- Result: [cURL bug bounty closed because of AI slop](#)



**AI CODE
SUMMIT**

by **SIMPLY**

PROBLEM #2

CVE SPAM AND AI SLOP

Takeaway for teams:

- the stream will not stop
- you need a process and automation, not "manual work only"



**AI CODE
SUMMIT**

by **SIMPLY**

PROBLEM #3

COST OF VULNERABILITY RESEARCH

For each vulnerability you need to:

- Understand **applicability** to our code and infrastructure
- Do **expert work** (static/dynamic analysis, fuzzing in a sandbox)



**AI CODE
SUMMIT**

by **SIMPLY**

PROBLEM #3

COST OF VULNERABILITY RESEARCH

- If you miss the window → you lose money, customers, reputation

This is an argument for a **pipeline** with clear steps and metrics.



**AI CODE
SUMMIT**

by **SIMPLY**

SECURE DEVELOPMENT LIFECYCLE

SDL is a common process for working with vulnerabilities and building secure architecture:

1. Architecture:

- HLA
- threat model
- attack surfaces
- diagrams → specs



**AI CODE
SUMMIT**

by **SIMPLY**

SECURE DEVELOPMENT LIFECYCLE

2. Third-party and open source:

- dependency report
- monitoring
- DevSecOps + SRE on-call for critical triage



**AI CODE
SUMMIT**

by **SIMPLY**

SECURE DEVELOPMENT LIFECYCLE

3. OWASP Top 10 as a starting vector for research



**AI CODE
SUMMIT**

by **SIMPLY**

WHAT TO AUTOMATE

Code (manual analysis → partial automation)

- Does the function receive user input?
- Is the library method really used in the product?



WHAT TO AUTOMATE

Static analysis / dynamic analysis / fuzzing

- Test generation
- Codebase exploration
- Finding gaps and gray areas



WHAT TO AUTOMATE

Pentest agents in sandboxes

- Buy a ready agent / SaaS instead of doing analysis yourself
- Run in tens of minutes → report



WHAT TO AUTOMATE

Pentest agents in sandboxes (report)

- vulnerabilities in containers
- infrastructure misconfigurations
- patch management recommendations



EXPERIENCE FROM SECURITY VENDORS

Any leader in the security industry can provide everything below

EXPERIENCE FROM SECURITY VENDORS

SIEM

- Event and traffic telemetry → correlation → alerts and incidents
- Auto-response, playbooks
- Expensive and needs experts → requires building a SOC (security operation center)



**AI CODE
SUMMIT**

by **SIMPLY**

EXPERIENCE FROM SECURITY VENDORS

VM + auto-pentesting

- Asset inventory, integration points with AI
- Vulnerability Assessment
- Patch management
- Automated pentests



**AI CODE
SUMMIT**

by **SIMPLY**

EXPERIENCE FROM SECURITY VENDORS

Container Security

- Automated research of containerized environments
- Runtime analysis
- Finding configuration errors



PLATFORM EXAMPLES

- **XBOW** — thousands of short-lived autonomous agents under an orchestrator;
- findings are confirmed with **challenge/exploit** in a controlled environment;
- public cases on **HackerOne** and with large vendors



PLATFORM EXAMPLES

- **NodeZero (Horizon3.ai)** — autonomous pentest "like a real attack": technique chains, proof of exploitation (incl. Active Directory, cloud); mix of ML and GenAI



**AI CODE
SUMMIT**

by **SIMPLY**

PLATFORM EXAMPLES

- **APT Bezdna (CTRLHACK)** — automated pentest platform: simulates attacker actions on the surface and gives a report for defense teams



**AI CODE
SUMMIT**

by **SIMPLY**

NON \$1 BILLION SOLUTION

Approach for a small team:

- **Security Champion** role
- **Threat modeling → specs**

(single source of truth for agents and people)

- Vulnerability handling:

analysis, **fix via automation**, deploy to **staging**, verification

Goal: autonomous business process, not hero work from single people.



THREE PROCESS METRICS

1. Volume

found and fixed vulnerabilities **by CVSS levels**

2. Speed

CVE published → applicability found for our system → **fix in prod**

3. Autonomy rate

manual work vs autonomous steps (percent by stage)



AI CODE
SUMMIT

by SIMPLY

APPLY THE SAME TO REGULAR BUGS

The same framework works for **bug fixing**:

- For business this is often **easier to understand** than a pure security pipeline
- You need a **source** to find bugs:
 - QA test cases** — again **specs** as the only source of truth about the system



THE TALK IN ONE SLIDE

1. Vulnerability process: HLA, threat model, and third-party code scanning
2. Vulnerability scoring and auto-fix for mature companies
3. Security Champion — fast and low-cost start



**AI CODE
SUMMIT**

by **SIMPLY**

PAVEL VOSTRIKOV

- t.me/vos3k
- [github/vostrik](https://github.com/vostrik)
- mail@vostrik.com





**AI CODE
SUMMIT**

by **SIMPLY**

THANK YOU!



SIMPLY

 **SYNERGY**

SIMPLY

 **SYNERGY**

SIMPLY